

INTERNAL AUDIT REPORT : CYCLE 1

Organization: VertexOne Digital Services

Audit Type: ISMS Internal Audit : Cycle 1

Standard: ISO/IEC 27001:2022

Reference: Clause 9.2 : Internal Audit

Lead Auditor: Junior GRC Analyst

Status: Submitted to CISO and Risk Committee

1. Executive Summary

The Cycle 1 internal audit reviewed six control areas covering access management, endpoint protection, security awareness, vulnerability management, backup, and supplier security.

The audit identified **two Major Nonconformities and three Minor Nonconformities**.

Overall, the ISMS demonstrates meaningful operational implementation in several areas. However, the identified Major Nonconformities require corrective action and verification before VertexOne should proceed toward external certification readiness.

2. Audit Scope

The audit covered the following ISO/IEC 27001:2022 Annex A controls:

- A.8.2 : Privileged Access Rights
- A.8.5 : Secure Authentication
- A.8.1 : User Endpoint Devices
- A.8.7 : Protection Against Malware
- A.6.3 : Information Security Awareness, Education and Training
- A.8.8 : Management of Technical Vulnerabilities
- A.8.13 : Information Backup
- A.5.19 : Information Security in Supplier Relationships

The audit reviewed evidence and control activity covering the period since implementation activities began.

3. Audit Methodology

The audit was performed using a combination of:

- Document review.

- Technical validation.
- Interviews with the CISO, IT Operations, HR, and Engineering Lead.
- Sampling of privileged accounts.
- Review of supplier security questionnaires.
- Review of security awareness training records.
- Review of vulnerability scanning and backup evidence.

Audit conclusions were based on the objective evidence available during fieldwork.

4. Audit Findings

Finding ID	Finding	Classification
F: 001	Backup restoration testing has never been performed.	Major Nonconformity
F: 002	Privileged access review is overdue.	Minor Nonconformity
F: 003	Security awareness completion is 68–72% and is inconsistent across regions.	Minor Nonconformity
F: 004	Supplier security reviews are incomplete for 2 of 4 critical vendors.	Minor Nonconformity
F: 005	Vulnerability scanning has gaps in 2 of the previous 8 weeks.	Major Nonconformity

5. Key Findings Summary

F: 001 : Backup Restoration Testing

Classification: Major Nonconformity

No documented backup restoration test has been performed.

This limits the organization's ability to demonstrate that backed: up information can be successfully restored when required.

Required Action: Establish and perform a documented restoration test and retain objective evidence of the result.

F: 002 : Privileged Access Review

Classification: Minor Nonconformity

The required quarterly privileged access review was overdue at the time of the audit.

Required Action: Complete the overdue review and establish monitoring to ensure future reviews are completed according to schedule.

F: 003 : Security Awareness Training

Classification: Minor Nonconformity

Security awareness training completion ranged between **68% and 72%**, with inconsistencies identified across regions.

Required Action: Address outstanding training and implement escalation or monitoring mechanisms for overdue employees.

F: 004 : Supplier Security Reviews

Classification: Minor Nonconformity

Security reviews or signed security addenda were incomplete for **2 of 4 critical vendors**.

Required Action: Complete outstanding supplier security reviews and track remediation to closure.

F: 005 : Vulnerability Scanning

Classification: Major Nonconformity

Vulnerability scanning records contained gaps in **2 of the previous 8 weeks**.

Required Action: Restore consistent scanning coverage, investigate the cause of the gaps, and implement monitoring to prevent recurrence.

6. Positive Practices

The audit identified several positive practices.

MFA and privileged access controls demonstrate a clear risk: based prioritization, even though some review activities remain incomplete.

The CISO also demonstrated a strong understanding of the organization's risk rationale and its relationship to the information security programme during the audit interview.

These practices provide a useful foundation for further ISMS improvement.

7. Overall Audit Conclusion

The audit determined that the ISMS is operating with meaningful evidence of implementation rather than relying solely on documented policies and procedures.

However, the identified **two Major Nonconformities : F: 001 and F: 005 : represent significant control weaknesses** that require corrective action.

VertexOne should **not proceed toward external certification readiness until the Major Nonconformities have been addressed, implemented, and independently verified as effective.**

The Minor Nonconformities should also be tracked through the corrective action process and monitored to prevent recurrence.

8. Corrective Action and Follow: up

Detailed corrective actions, responsible owners, target dates, and verification methods are maintained in the **Corrective Action Register**.

Follow: up verification will be documented in the **Audit Follow: up Tracker**.

Finding Corrective Action Register Follow: up Verification

F: 001	Required	Required
F: 002	Required	Required
F: 003	Required	Required
F: 004	Required	Required
F: 005	Required	Required

9. Report Approval

Role	Responsibility	Status
Lead Auditor	Junior GRC Analyst	Prepared
Audit Review	GRC Manager	Reviewed

Role	Responsibility	Status
Management Recipient	CISO	Submitted
Risk Oversight	Risk Committee	Submitted

Report Status: Submitted to CISO and Risk Committee

Prepared By: Junior GRC Analyst

Date: _____